UNIVERSITY OF SOUTH CAROLINA

ITEC 493: IT Security for Managers

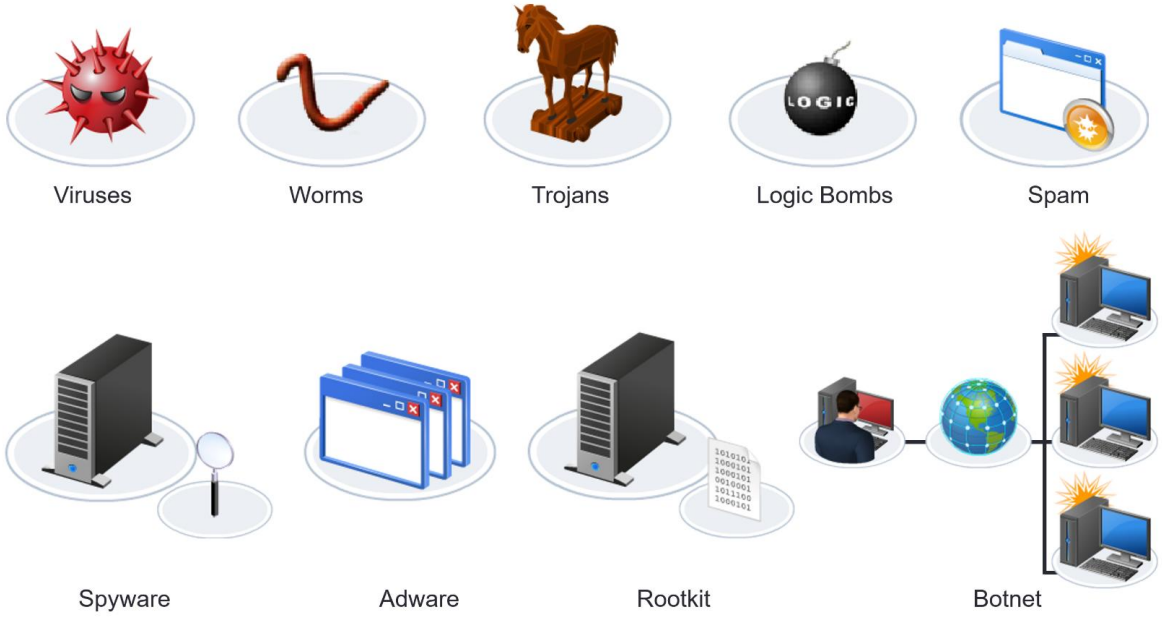
Malware and Social Engineering

Ali Mazloum
Integrated Information Technology Department
College of Engineering and Computing
University of South Carolina

Fall 2025

Attacks Using Malware

- **Malware** is software that enters a computer system without the user's knowledge or consent and then performs an unwanted and harmful action
- Malware is continually evolving to avoid detection by improved security measures
- One attempt at classifying the diverse types of malware can be to examine the primary action that the malware performs:
  - Imprison
  - Launch
  - Snoop
  - Deceive
  - Evade



Imprison (1 of 4)

- Some types of malware attempt to take away the freedom of the user to do what they want
- Types of malware that imprisons are ransomware and cryptomalware
- Ransomware
  - **Ransomware** prevents a user's endpoint device from properly and fully functioning until a fee is paid
  - Some ransomware pretends to come from a law enforcement agency while others pretend to come from a software vendor and displays a fictitious warning that a license has expired

Imprison (2 of 4)

Source: Symantec Security Response

Figure 3-1 Blocker ransomware message

Source: Used with permissions from Microsoft

Figure 3-2 Ransomware computer infection

Imprison (3 of 4)

- Cryptomalware
  - **Cryptomalware** is a type of malware that imprisons users and encrypts all files on the device so that none of them can be opened
  - The cost for the key to unlock the cryptomalware increases every few hours or days
  - New variants of cryptomalware encrypt all files on any network or attached device connected to that computer

Imprison (4 of 4)

Source: Bitcoin

Figure 3-3 Cryptomalware message

Launch (1 of 5)

- Malware that infects a computer to launch attacks on other computers includes a virus, worm, and bot
- Virus
  - There are two types of viruses: a file-based virus and a fileless virus
  - A *file-based virus* is malicious code that is attached to a file that reproduces itself on the same computer without any human intervention
  - An *armored file-based virus* goes to great lengths to avoid detection
    - Techniques include *split infection* and *mutation*
  - The virus first unloads a payload to perform a malicious action, then the virus replicates itself by inserting its code into another file (on the same computer)

Launch (2 of 5)

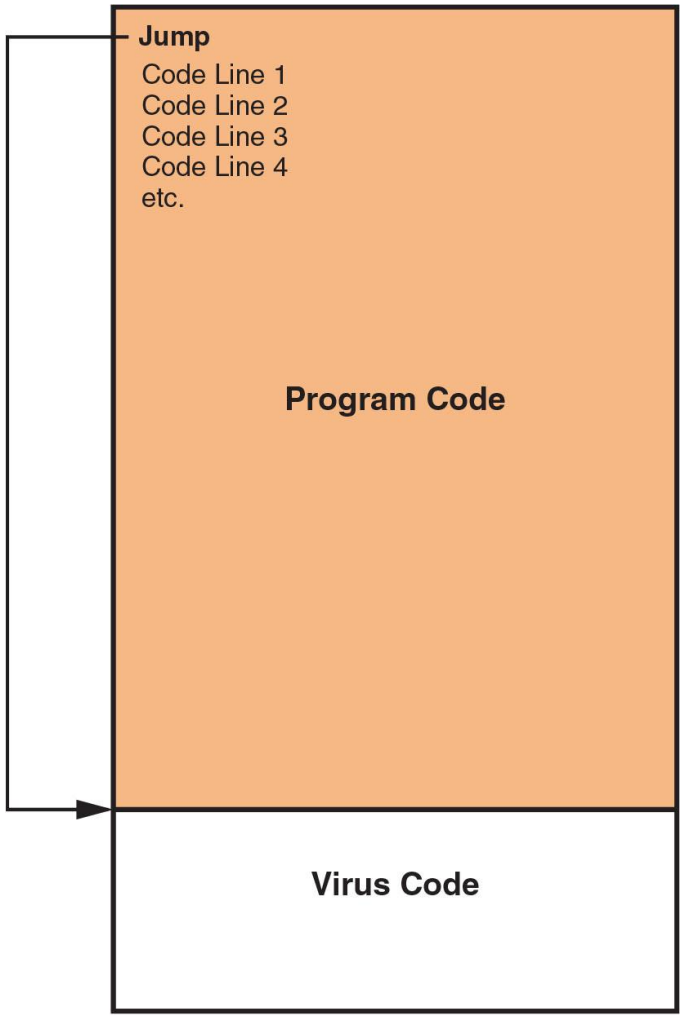


Figure 3-4 Appender infection

Launch (2 of 5)

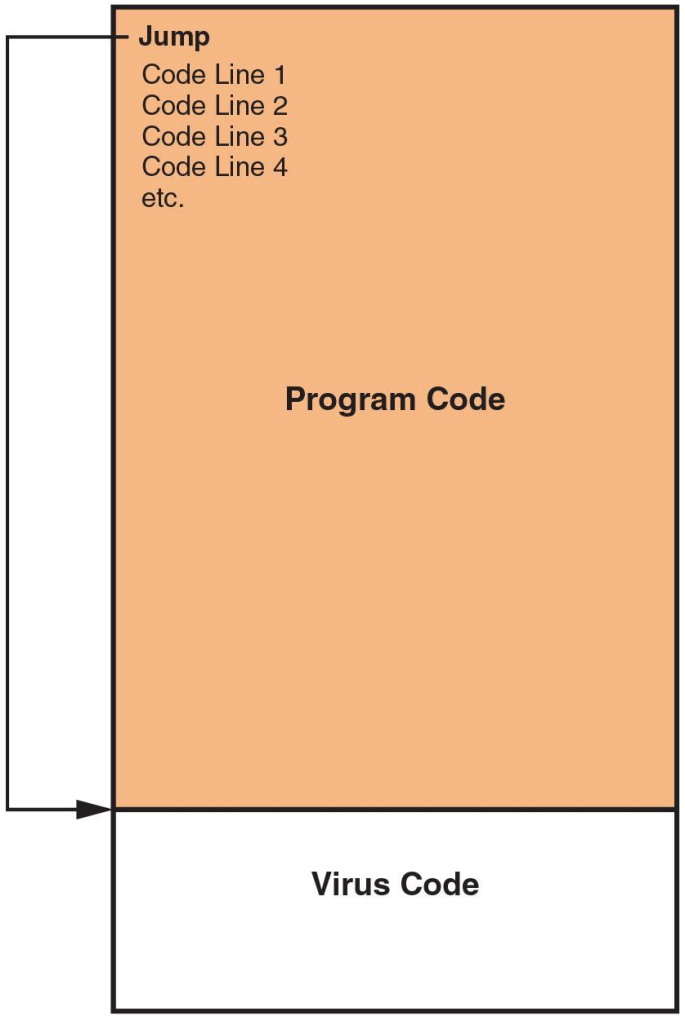
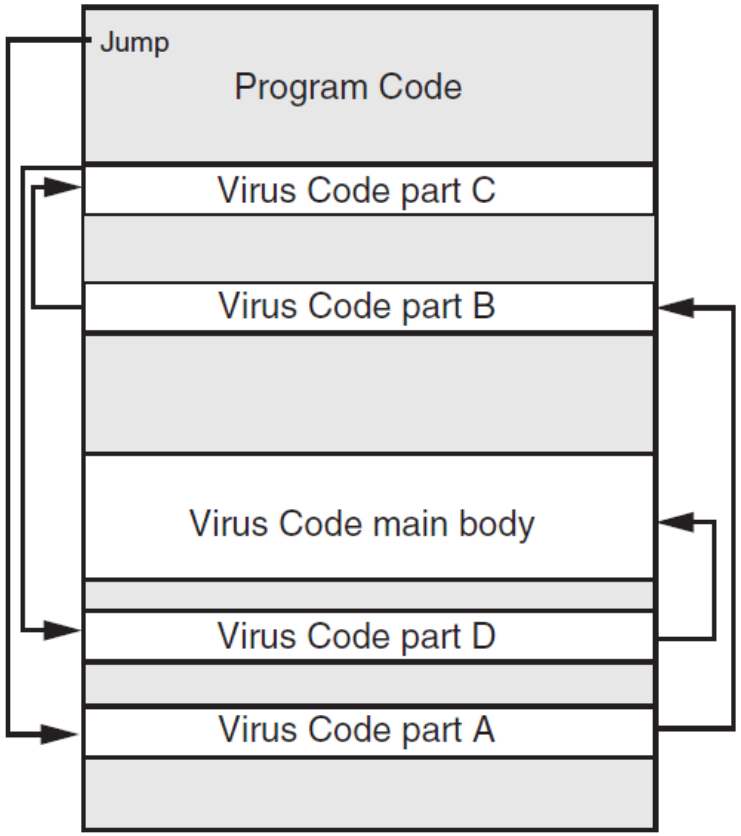


Figure 3-4 Appender infection



Split Infection

Launch (3 of 5)

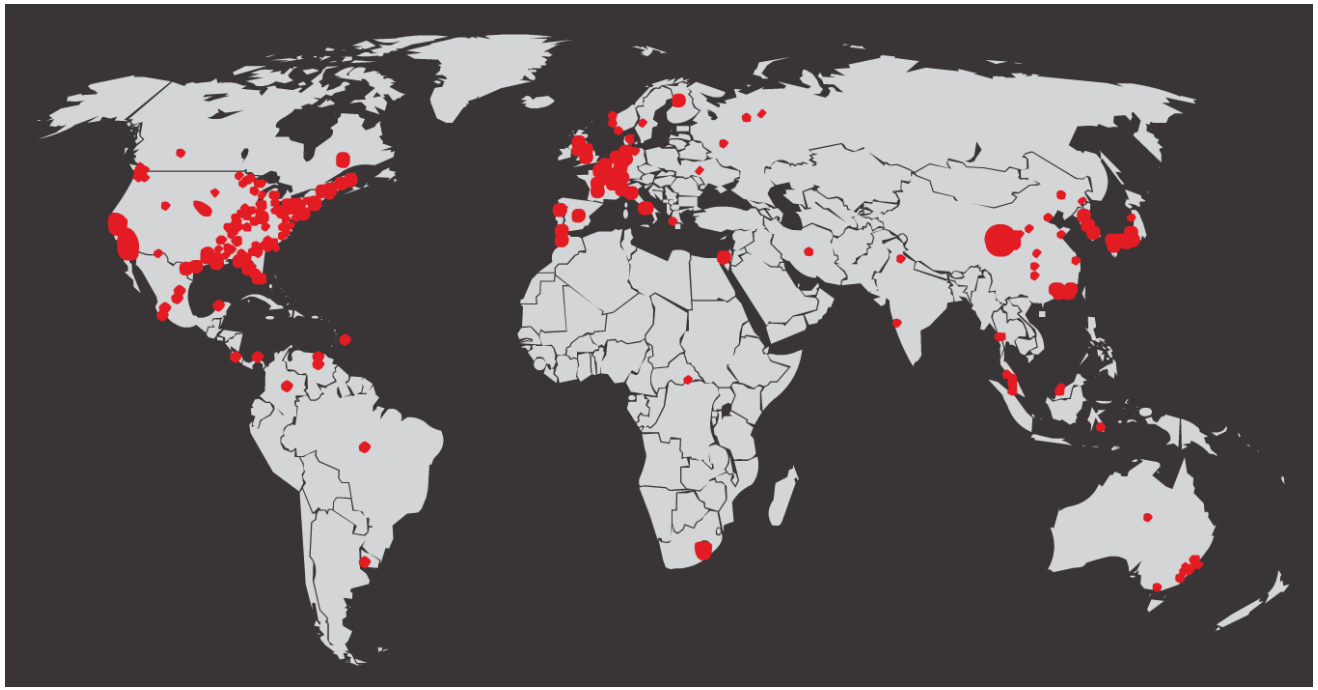
- A **fileless virus** does not attach itself to a file but instead takes advantage of native services and processes that are part of the OS to avoid detection and carry out its attacks
  - It does not infect a file, instead the code is loaded directly in the computer's random access memory (RAM)
- Advantages of a fileless virus over a file-based virus:
  - *Easy to infect*
  - *Extensive control*
  - *Persistent*
  - *Difficult to detect*
  - *Difficult to defend against*

Launch (4 of 5)

- Worm
  - A **worm** is a malicious program that uses a computer network to replicate (sometimes called a network virus)
  - Designed to enter a computer through the network and then take advantage of a vulnerability in an application or an OS on the host computer
  - Today's worms can leave behind a payload on the systems they infect and cause harm, much like a virus
  - Actions that worms have performed include deleting files on the computer or allowing the computer to be remotely controlled by an attacker

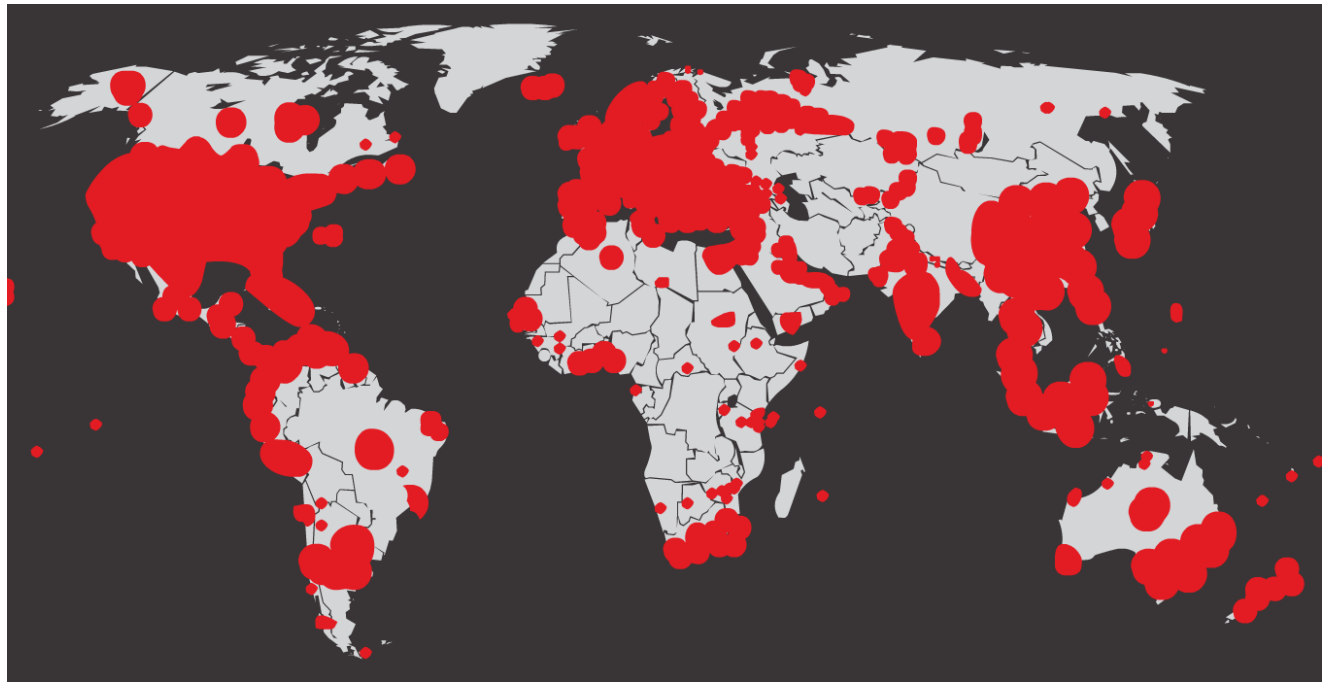
Worm

- Worms are responsible for some of the most devastating attacks on the Internet
- In 2001, Code Red worm infected 658 servers. Within 19 hours, the worm had infected over 300,000 servers



Worm

- Worms are responsible for some of the most devastating attacks on the Internet
- In 2001, Code Red worm infected 658 servers. Within 19 hours, the worm had infected over 300,000 servers



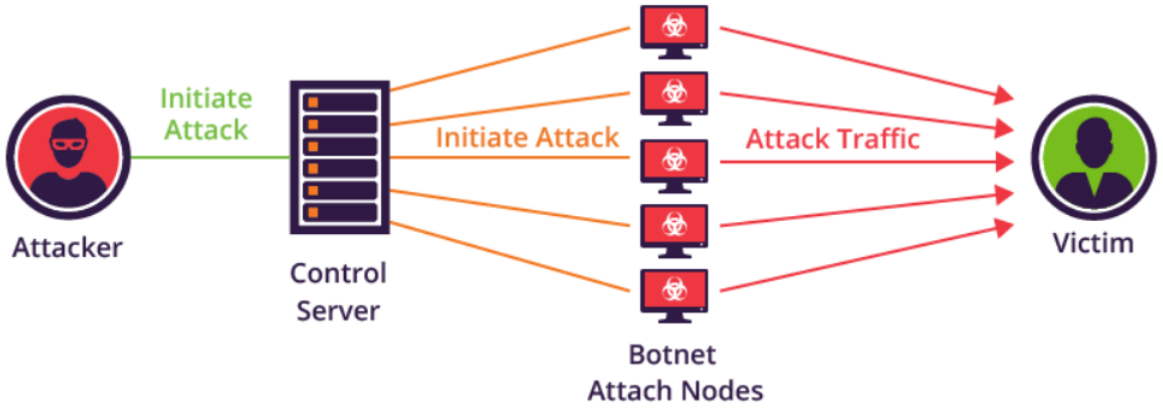
Virus vs Worm

- Differences

Action	Virus	Worm
What does it do?	Inserts malicious code into a program or data file	Exploits a vulnerability in an application or operating system
How does it spread to other computers?	User transfers infected files to other devices	Uses a network to travel from one computer to another
Does it infect a file?	Yes	No
Does there need to be user action for it to spread?	Yes	No

Launch (5 of 5)

- Bot
  - Another type of malware allows the infected computer to be placed under the remote control of an attacker for the purpose of launching attacks
  - The infected robot computer is known as a **bot** or *zombie*
  - When hundreds, thousands, or even millions of bot computers are gathered into a logical computer network, they create a *botnet* under the control of a *bot herder*
  - Infected bot computers receive instructions through a command and control (C&C) structure from the bot herders



Snoop (1 of 2)

- Two common types of snooping malware are spyware and keyloggers
- Spyware
  - **Spyware** is tracking software that is deployed without the consent or control of the user
- Keylogger
  - A **keylogger** silently captures and stores each keystroke that a user types on the computer's keyboard
  - The threat actor can then search the captured text for any useful information such as passwords, credit card numbers, or personal information
  - A keylogger can be a software program or a small hardware device

Snoop (2 of 2)

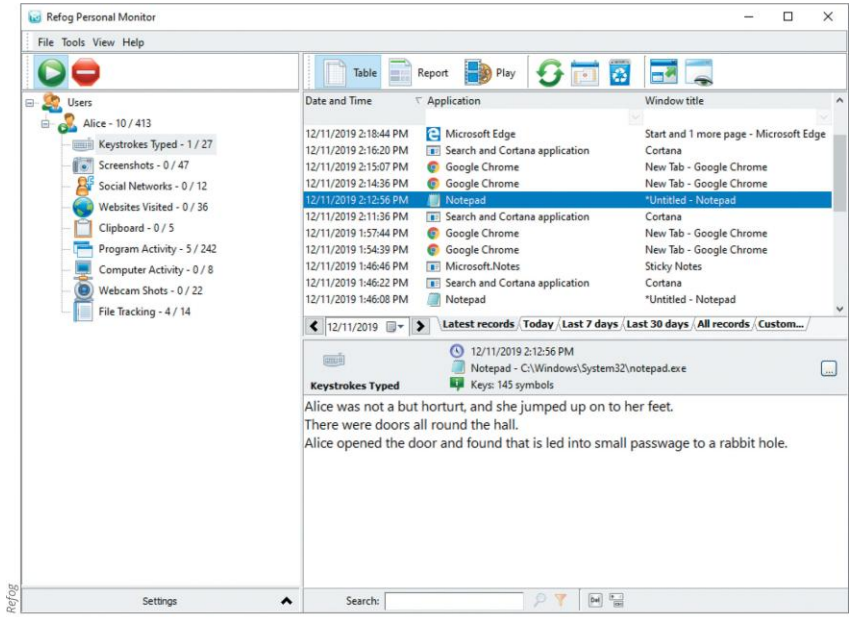


Figure 3-5 Software keylogger

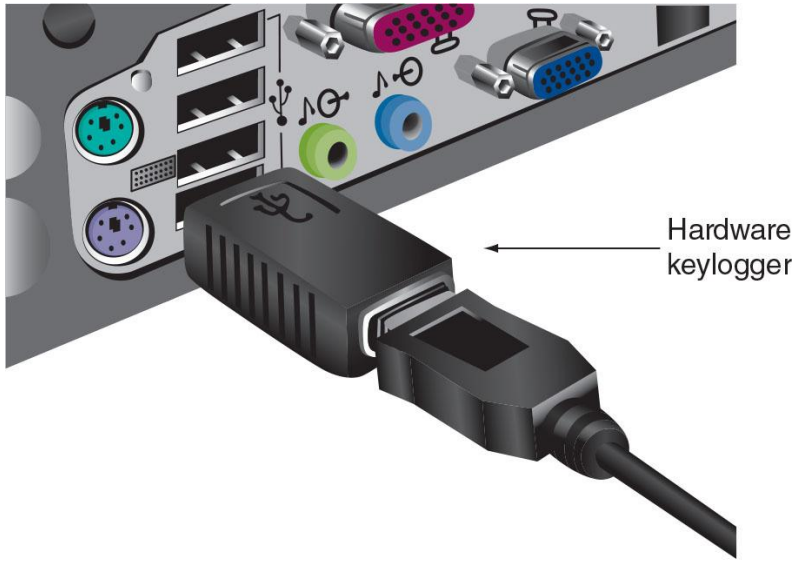


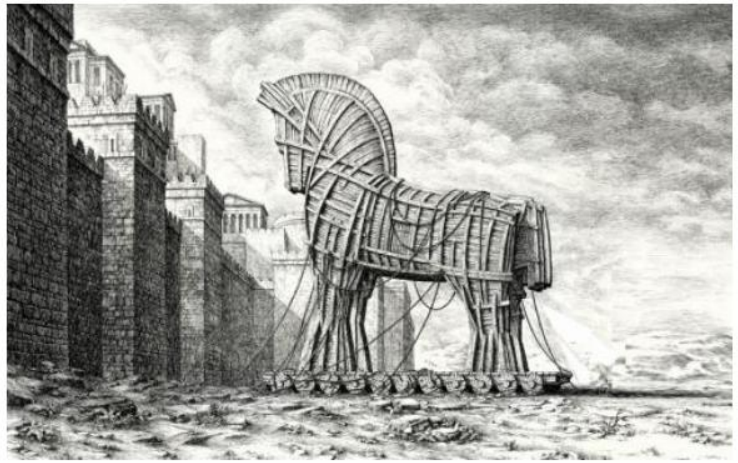
Figure 3-6 Hardware keylogger

Deceive (1 of 2)

- Some malware attempts to deceive the user and hide its true intentions
- Examples include potentially unwanted programs (PUPs), Trojans, and remote access Trojans (RATs)
- **Potentially Unwanted Program (PUP)**
  - A PUP is software that the user does not want on their computer
  - Examples of PUPs:
    - Advertising that obstructs content or interferes with web browsing, pop-up windows, pop-under windows, search engine hijacking, home page hijacking, etc

Deceive (2 of 2)

- Trojan
  - A computer **Trojan** is an executable program that masquerades as performing a benign activity but also does something malicious
- Remote Access Trojan (RAT)
  - A **RAT** has the basic functionality of a Trojan but also gives the threat agent unauthorized remote access to the victim's computer by using specially configured communication protocols
  - This creates an opening to the victim's computer allowing the threat agent unrestricted access



Evade

- This category of malware attempts to help malware or attacks evade detection
  - Includes backdoor, logic bomb, and rootkit
- Backdoor
  - A **backdoor** gives access to a computer, program, or service that circumvents any normal security protections
- Logic bomb
  - A **logic bomb** is computer code that is typically added to a legitimate program but lies dormant and evades detection until a specific logical event triggers it
- Rootkits
  - A **rootkit** is malware that can hide its presence and the presence of other malware on the computer
    - It does this by accessing “lower layers” of the OS to make alterations

Logic bomb examples

Description	Reason for attack	Results
A logic bomb was planted in a financial services computer network that caused 1000 computers to delete critical data.	A disgruntled employee had counted on this to cause the company's stock price to drop; he planned to use that event to earn money.	The logic bomb detonated but the employee was caught and sentenced to 8 years in prison and ordered to pay $3.1 million in restitution.[6]
A logic bomb at a defense contractor was designed to delete important rocket project data.	The employee's plan was to be hired as a highly paid consultant to fix the problem.	The logic bomb was discovered and disabled before it triggered. The employee was charged with computer tampering and attempted fraud and was fined $5000.[7]
A logic bomb at a health services firm was set to go off on the employee's birthday.	The employee was angered that he might be laid off (although he was not).	The employee was sentenced to 30 months in a federal prison and paid $81,200 in restitution to the company.[8]

6. "History and milestones," *About RSA Conference*, accessed Mar. 3, 2011, www.rsaconference.com/about-rsa-conference/history-and-milestones.htm.
7. "Logic bombs," *Computer Knowledge*, accessed Mar. 3, 2011, www.cknow.com/cms/vtutor/logic-bombs.html.
8. Vijayan, Jaikumar, "Unix admin pleads guilty to planting logic bomb," *Computerworld*, Sep. 21, 2007, accessed Mar. 3, 2011, www.pcworld.com/article/137479/unix_admin_pleads_guilty_to_planting_logic_bomb.html.

Social Engineering Attacks (1 of 8)

- **Social engineering** is a means of **eliciting information** (gathering data) by relying on the weaknesses of individuals
  - It is also used as influence campaigns to sway attention and sympathy in a particular direction
  - These campaigns can be found exclusively on social media or may be combined with other sources
- Psychological Principles
  - Attackers use a variety of techniques to gain trust:
    - *Provide a reason*
    - *Project confidence*
    - *Use evasion and diversion*
    - *Make them laugh*

Social Engineering Attacks (2 of 8)

- Social engineering psychological approaches often involve:
  - **Impersonation** is masquerading as a real or fictitious character and then playing the role of that person with a victim
  - **Phishing** is sending an email message or displaying a web announcement that falsely claims to be from a legitimate enterprise in an attempt to trick the user into surrender private information or taking action
    - Variations on phishing attacks:
      - *Spear phishing*
      - *Whaling*
      - *Vishing*
      - *Smishing*

Social Engineering Attacks (3 of 8)

- Social engineering psychological approaches often involve (continued):
  - **Redirection** is when an attacker directs a user to a fake lookalike site filled with ads for which the attacker receives money for traffic generated to the site
    - Attackers purchase fake sites because the domain names of sites are spelled similarly to actual sites (called **typo squatting**)
    - Another redirection technique is **pharming** where the attacker attempts to exploit how a URL is converted into its corresponding IP address
  - **Spam** is unsolicited email that is sent to a large number of recipients
    - Text-based spam messages can be filtered
    - Image spam cannot be filtered
    - **Spim** is spam delivered through instant messaging (IM) instead of email

Social Engineering Attacks (4 of 8)

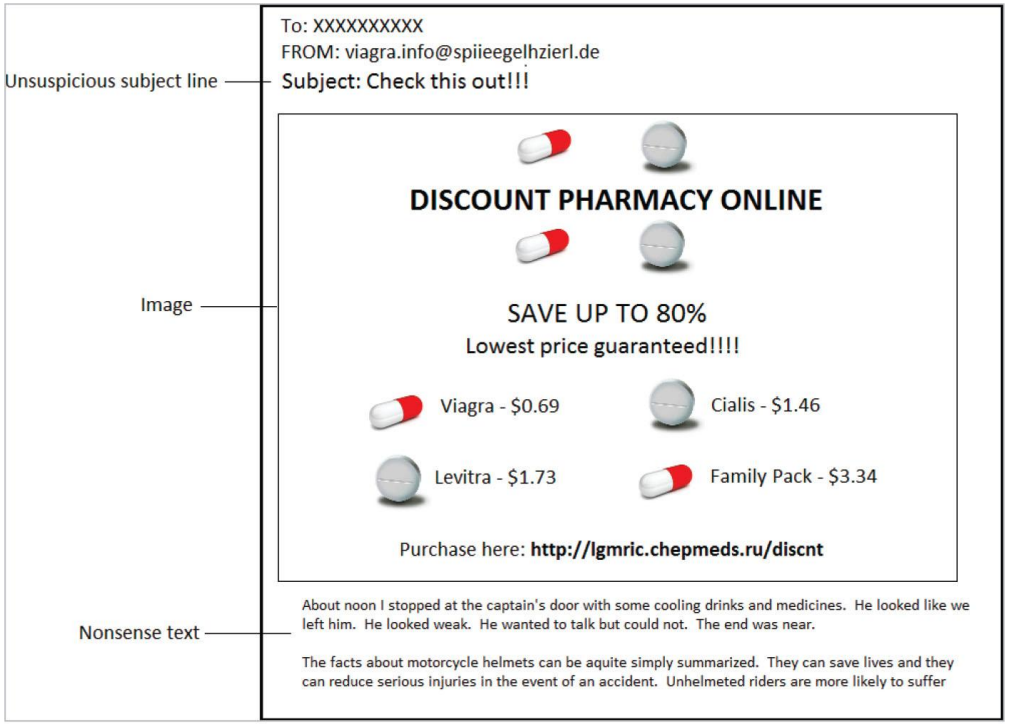


Figure 1-6 Image spam

Social Engineering Attacks (5 of 8)

- Social engineering psychological approaches often involve (continued):
  - **Hoaxes** are false warnings, often contained in an email message claiming to come from the IT department
    - The hoax purports that there is a “deadly virus” circulating through the Internet and the recipient should erase specific files or change security configurations
  - A **watering hole attack** is directed toward a smaller group of specific individuals

Social Engineering Attacks (6 of 8)

- Physical Procedures
  - Physical attacks take advantage of user actions that can result in compromised security
  - Three of the most common physical procedures are dumpster diving, tailgating, and shoulder surfing
  - **Dumpster Diving** involves digging through trash receptacles to find information that can be useful in an attack
    - An electronic variation of physical dumpster diving is to use the Google search engine to look for documents and data posted online that can be used in an attack (called *Google dorking*)

Social Engineering Attacks (7 of 8)

Item retrieved	Why useful
Calendars	A calendar can reveal which employees are out of town at a particular time.
Inexpensive computer hardware, such as USB flash drives or portal hard drives	These devices are often improperly disposed of and might contain valuable information.
Memos	Seemingly unimportant memos can often provide small bits of useful information for an attacker who is building an impersonation.
Organizational charts	These identify individuals within the organization who are in positions of authority.
Phone directories	A phone directory can provide the names and telephone numbers of individuals in the organization to target or impersonate.
Policy manuals	These may reveal the true level of security within the organization.
System manuals	A system manual can tell an attacker the type of computer system that is being used so that other research can be conducted to pinpoint vulnerabilities.

Social Engineering Attacks (8 of 8)

- Physical Procedures (continued)
  - **Tailgating** occurs when an authorized person opens an entry door, one or more individuals can follow behind and also enter
  - **Shoulder Surfing** allows an attacker to casually observe someone entering secret information, such as the security codes on a door keypad